NCAOS / EGS — Phase 06 Architecture

Hardening & Compliance · STRIDE · AI/ML Threat Model · ISO 42001 · Pen Test · Chaos · ADR-007 · v0.6.0

229 TESTS | 11 PEN TESTS | ALL PASS | F-01 FIXED | v0.6.0 | ADR

PRIOR PHASES

Phase 06 adds @ncaos/hardening only

- @ncaos/core — Ph 01 — 47t
- @ncaos/shell — Ph 02 — 15t
- @ncaos/api — Ph 04 — 65t
- @ncaos/detection — Ph 03 — 54t
- @ncaos/ui — Ph 05 — manual
- audit-signal — Ph 05 — AS-01→03

181 PASSING

Phase 01–05 base

@ncaos/hardening · Phase 06 · 7 source files · 5 test files · 48 tests · ADR-007

STRIDE Register
stride-model.ts
- 15 threats · 6 categories
- HIGH: S-001, T-002, D-001, E-001

AI/ML Threats
aiml-threat-model.ts
- 12 threats: AdversarialInput
- ModelDrift (F-01) · ContextManip
- egsMitigation per threat

JWT + RateLimiter
auth-middleware.ts
- JWT HS256 · RBAC roles
- operator/admin/auditor
- 100 req/s burst 150

ISO 42001
iso42001-mapping.ts
- 14 controls mapped
- 8 IMPL · 3 PARTIAL · 1 PLANNED
- coveragePercent ≥ 70%

Pen Test Harness
pentest-scenarios.ts
- 11 scenarios
- PT-001→PT-010 + PT-CHAOS-001
- PowerShell cmds for HIGH

Chaos Harness
chaos-harness.ts
- 5 scenarios
- CHAOS-001: ADR-002 invariant
- CHAOS-002: rate limit unit

stride-model.ts

STRIDE Threat Model · 15 Threats · 6 Categories · 4 HIGH · stride-model.ts || Pen Test Matrix · 11 Scenarios · pentest-scenarios.ts

S-001	HIGH	Spoofing	X-Partner-ID forgery
S-002	MED	Spoofing	sourceId spoofing
S-003	MED	Spoofing	WebSocket no auth
T-001	LOW	Tampering	Evidence handles
T-002	HIGH	Tampering	POST /v1/policy
T-003	MED	Tampering	Input field injection
T-004	LOW	Tampering	Shell kill
R-001	MED	Repudiation	Evidence log
R-002	MED	Repudiation	Policy history
I-001	MED	Info Disclose	Error stack traces
I-002	MED	Info Disclose	WebSocket stream
I-003	LOW	Info Disclose	MTTD endpoint
D-001	HIGH	DoS	POST /v1/process flood
D-002	MED	DoS	EventStore ingestion
E-001	HIGH	Elev. Priv.	POST /v1/policy bypass

STRIDE ref

PEN TEST RESULTS

PT-001	Tenant Spoofing	PASS
PT-002	Source ID Spoofing	NOTED
PT-003	WebSocket No Auth	DEFER
PT-004	Policy Weakening	PASS
PT-005	Evidence Handle Manip	PASS
PT-006	Prompt Injection	DEFER
PT-007	DoS /v1/process Flood	PART
PT-008	Authority Escalation	PASS
PT-009	Error Info Leakage	DEFER
PT-010	CORS Misconfiguration	DEFER
PT-CHAOS	Shell Kill FAIL_SAFE	PASS

iso42001-mapping.ts

* DEFER = Phase 07 action. PART = PowerShell loop too slow.

ISO 42001:2023

14 controls mapped · iso42001-mapping.ts

- 6.1.2 GateDetector rules
- 6.2 PolicyProfile monitoring
- 8.4 ShellLoop + Watchdog
- 8.6 ContinuityDetector equiv.
- 9.2 Evidence + AuditSignal
- 10.1 BLOCK + routing hints
- 7.2 Human oversight trail
- 6.1.3 STRIDE + AI/ML models
- 8.3 Obs-Judge-Enforcer loop
- 8.5 TenantDetectorRegistry
- 9.1 MTTD SLA all 4 layers
- 9.3 SequenceSummary (TW)
- 10.2 Phase 06 hardening
- 5.2 Policy leadership

8 IMPLEMENTED | 3 PARTIAL | 1 PLANNED

MTTD SLA Baseline

1000 iterations / layer · Phase 07 contract

LAYER	SLA	p99	BREACH
gate	≤ 50ms	0.03ms	0.00%
premise	≤ 200ms	0.05ms	0.00%
authority	≤ 100ms	0.03ms	0.00%
continuity	≤ 500ms	0.05ms	0.00%

5/5 TESTS PASS

Chaos Harness

chaos-harness.ts · 8/8 PASS

CHAOS-001	Shell Kill → FAIL_SAFE	ADR-002	Manual
CHAOS-002	Rate Limit Exhaustion	D-001	Unit
CHAOS-003	Network partition	ADR-002	Documented
CHAOS-004	Memory pressure	ADR-002	Documented
CHAOS-005	Clock skew	MTTD	Documented

PT-CHAOS-001 observed:
3/20 requests → 'Connection failed during restart = PASS'
Post-restart: ShellLoop reinit, schema validation active.

ADR-007 + Fix

Phase 06 Security Hardening Strategy

- docs/adr/ADR-007-phase06-security-hardening.md
- JWT HS256 middleware design rationale
- RateLimiter token-bucket implementation
- Chaos test scope — CHAOS-001 ADR-002 link
- Phase 07 roadmap: HMAC, stack trace strip,
- WebSocket auth, sourceId signing

F-01 aiml-threat-model.ts
category 'DriftExploitation'→'ModelDrift'
egsMitigation added to all 12 threats
2 iso42001.test.ts failures → cleared